

End-to-End Mini Project: Building an AI-Driven Cyber Threat Awareness and Detection Prototype

Lab Assignment : 01 (from Unit - 1) — Foundations of AI in Cyber Security

Course: AI in Cyber Security Lab	Student Name: Rohit Raj
Course Code: ENSP355	University: K.R. Mangalam University
Weightage: 20% of Lab Assessment	Faculty: Dr. Amar Saraswat
Repository: ai-cybersecurity-unit1-mini-project	Date: October 2026

1. Problem Overview & Real-World Cyber Threat Context

Modern corporate and governmental infrastructures face escalating threat volumes from sophisticated social engineering, credential-harvesting websites, and automated evasive phishing attacks. Traditional defense perimeter mechanisms (such as static reputation blocklists and signature-based heuristic rules) fail against dynamic domain generation algorithms (DGAs), multi-stage redirectors, and novel zero-hour malicious domains. This mini-project simulates an entry-level cyber security analyst developing an intelligent, data-driven security analysis and threat classification engine capable of distinguishing legitimate web resources from cyber threats while critically assessing operational false positives, bias, and deep learning feasibility.

2. System Architecture & Methodology

The prototype pipeline was designed using a rigorous, reproducible machine learning engineering workflow:

- **Environment Bootstrap:** Python 3.13 virtual environment with Scikit-learn, NumPy, Pandas, Matplotlib, Seaborn, UCIMLRepo, and Jupyter.
- **Dataset Sourcing & Harmonization:** Ingestion of the verified UCI Phishing Websites benchmark dataset (ID 327, 11,055 instances, 30 features). Class labels were standardized to 1 = Phishing (Malicious Threat) and 0 = Legitimate (Normal Traffic).
- **Data Cleansing & Preprocessing:** Median imputation for missing numeric indicators, one-hot encoding for categorical variables, and z-score standard normalization (StandardScaler) inside encapsulated Scikit-learn Pipelines to avoid data leakage.
- **Stratified Data Partitioning:** 80% training (8,844 samples) and 20% testing (2,211 samples) using a fixed random seed (42) to guarantee reproducible comparative baselines.
- **Multi-Paradigm Modeling:** Training and evaluating a linear baseline (Logistic Regression), a non-linear rule tree (Decision Tree), and a deep multi-layer neural network (MLPClassifier).
- **Ethical & Operational Simulation:** Detailed threshold variation (0.10 to 0.90) measuring the real-world operational trade-off between False Positives (user lockouts) and False Negatives (breaches), alongside proxy-group fairness and privacy analysis.

3. Cyber Security Threat Landscape Analysis (EDA)

Exploratory Data Analysis revealed key behavioral anomalies that distinguish phishing campaigns from benign web infrastructure. The dataset exhibits a balanced distribution with 6,157 legitimate websites (55.7%) and 4,898 phishing websites (44.3%).

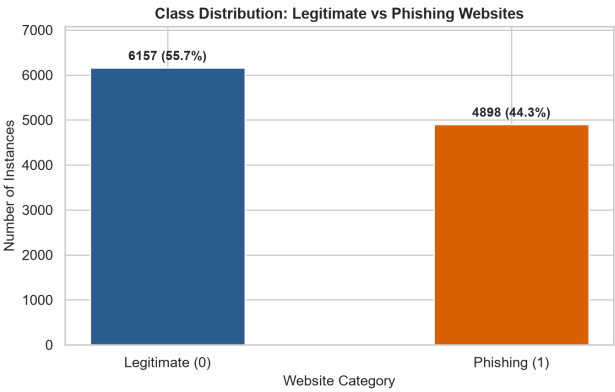


Figure 1: Target Class Distribution

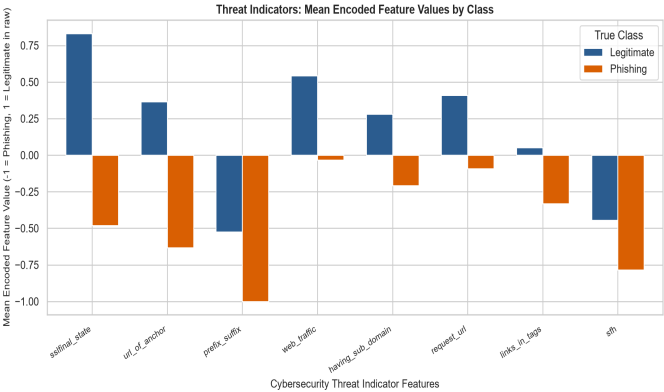


Figure 2: Mean Indicator Values by Website Class

Key Threat Indicator Insights: As shown in Figure 2, features such as sslfinal_state (validity of SSL/TLS certificate, issuer trust, and certificate age), url_of_anchor (percentage of hyperlinks pointing to differing external domains), prefix_suffix (presence of hyphens disguising brand names), and web_traffic (Alexa global ranking) exhibit sharp divergence between classes. Legitimate domains show predominantly positive values (+1), whereas phishing domains show negative encoded values (-1), confirming strong discriminative signal.

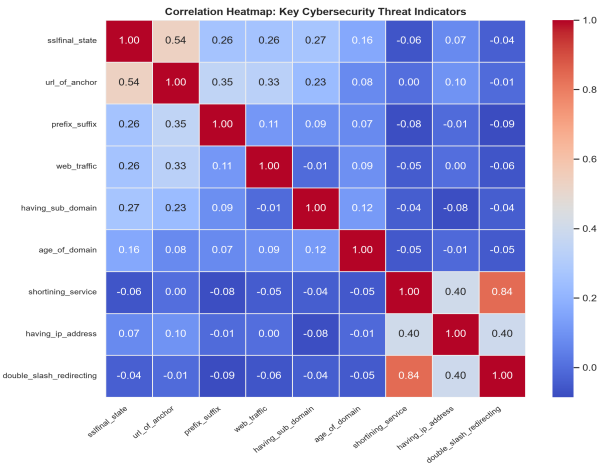


Figure 3: Indicator Correlation Heatmap

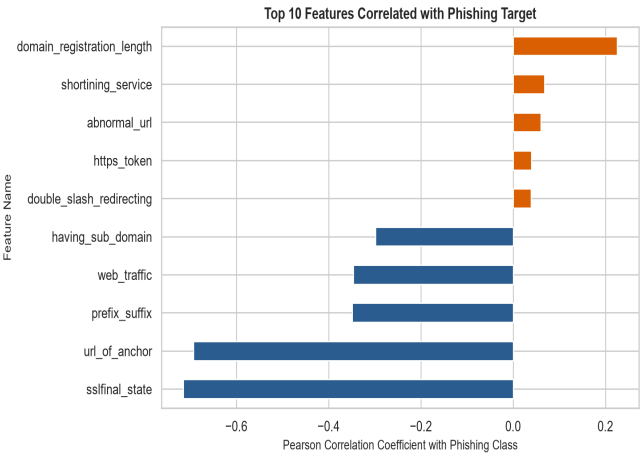


Figure 4: Top Features Correlated with Phishing Target

4. Machine Learning & Deep Learning Model Implementation

To rigorously address Tasks 3 and 4, three distinct architectural paradigms were trained and validated on the identical 80/20 stratified split:

- 1. **Logistic Regression (Supervised ML Baseline):** Scaled linear model with L2 regularization, serving as an ultra-low-latency classification benchmark.
- 2. **Decision Tree Classifier (Rule-Based ML):** Non-linear partitioning with maximum depth 6, generating auditable if-then decision trees suitable for tier-1 security analyst inspection.
- 3. **Multi-Layer Perceptron - MLP (Deep Learning Prototype):** Neural network featuring hidden architecture (64, 32), ReLU activation functions, Adam optimizer, and early stopping to prevent overfitting.

Quantitative Comparative Evaluation

Each architecture was evaluated across test Accuracy, Precision (minimizing false alarms), Recall (catching threats), F1-Score, ROC-AUC, and Training Execution Latency:

Model Architecture	Accuracy	Precision	Recall	F1-Score	ROC-AUC	Train Time
Logistic Regression	0.9281	0.9344	0.9010	0.9174	0.9785	0.061s
Decision Tree	0.9303	0.9249	0.9173	0.9211	0.9815	0.048s
MLP Neural Network	0.9656	0.9699	0.9520	0.9609	0.9944	2.442s

Table 1: Performance Benchmark on Stratified Test Set (2,211 instances)

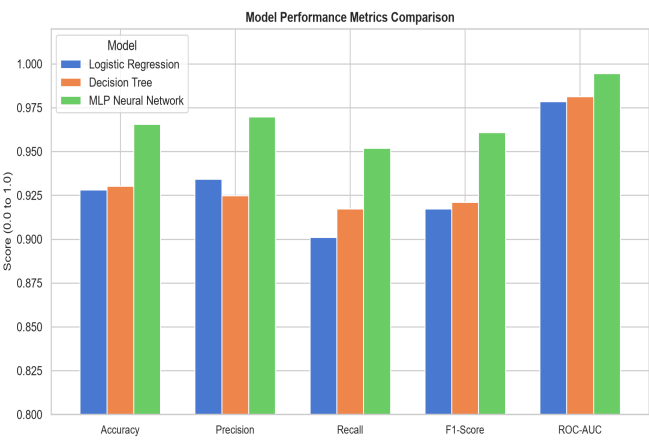
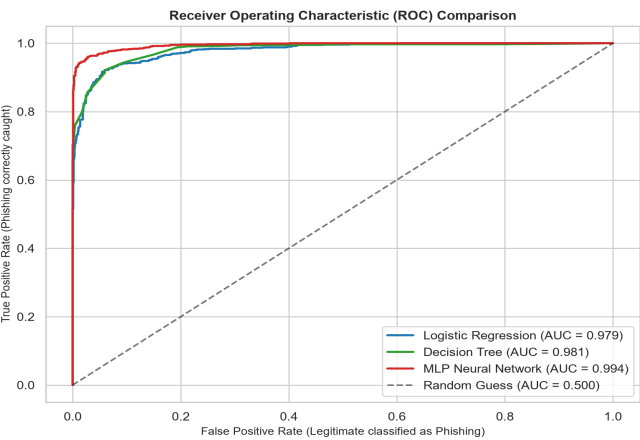


Figure 5: Receiver Operating Characteristic (ROC) Curves

Figure 6: Multi-Metric Performance by Architecture

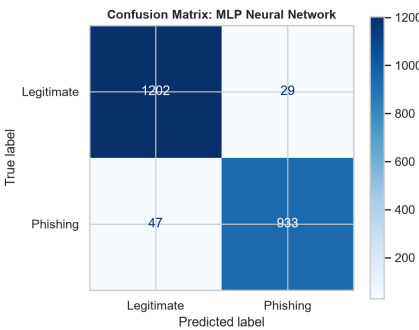
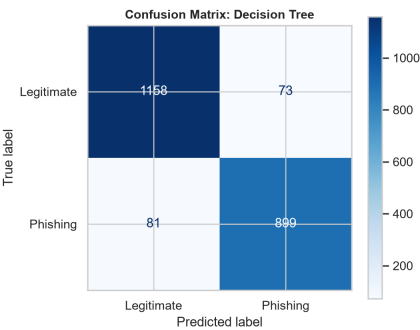
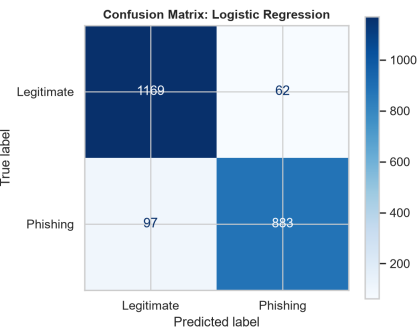


Figure 7a: CM — Logistic Regression

Figure 7b: CM — Decision Tree

Figure 7c: CM — MLP Neural Network

5. Ethical Reflection, Bias & Operational AI Challenges

Deploying artificial intelligence inside automated cyber defense environments introduces critical ethical, legal, and operational dilemmas. Task 5 mandates evaluating the direct consequences of classification thresholds, algorithmic bias, privacy violations, and explainability deficits.

5.1 Operational Error Simulation: False Positives vs False Negatives

In security operations, errors carry asymmetric real-world consequences:

- **False Positives (Legitimate Users Blocked):** A legitimate business domain, customer checkout portal, or partner API is incorrectly labeled as malicious. This causes immediate operational blockage, direct revenue loss, brand reputation damage, and severe Helpdesk alert fatigue.
- **False Negatives (Phishing Attacks Missed):** An active phishing site bypasses detection, enabling credential theft, multi-factor authentication (MFA) token hijacking, ransomware distribution, and catastrophic organizational breach.

Threshold	Accuracy	Precision	Recall	F1-Score	False Positives (Blocked)	False Negatives (Missed)
0.10	0.8616	0.7696	0.9816	0.8628	288	18
0.20	0.9005	0.8461	0.9480	0.8941	169	51
0.30	0.9254	0.8983	0.9378	0.9176	104	61
0.40	0.9308	0.9224	0.9214	0.9219	76	77
0.50	0.9281	0.9344	0.9010	0.9174	62	97
0.60	0.9272	0.9475	0.8847	0.9150	48	113
0.70	0.9199	0.9557	0.8592	0.9049	39	138
0.80	0.9104	0.9700	0.8235	0.8907	25	173
0.90	0.8801	0.9825	0.7429	0.8460	13	252

Table 2: Threshold Variation & Error Trade-off Analysis (Logistic Regression)

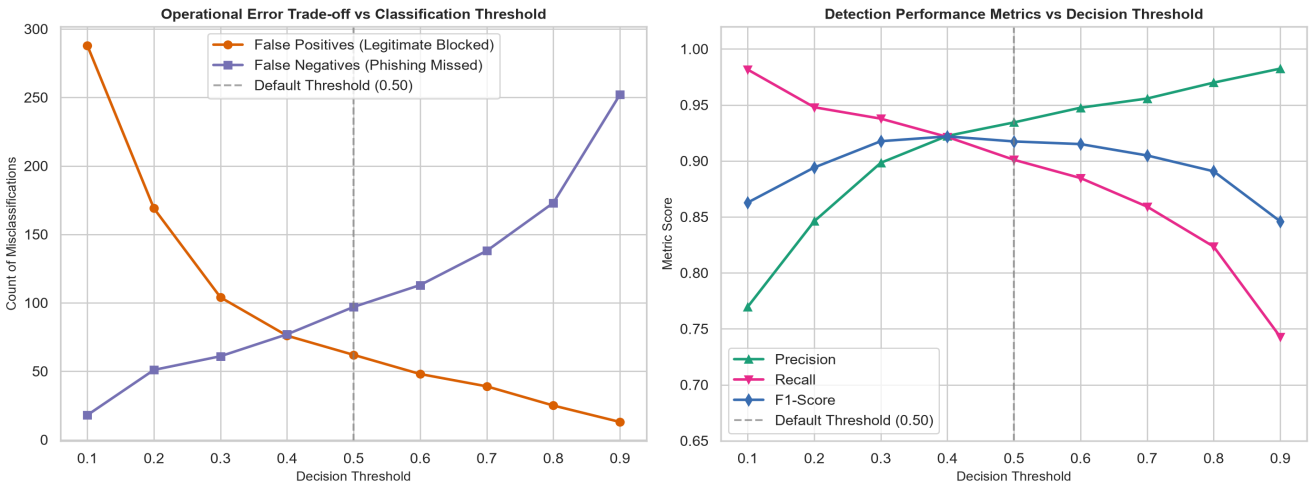


Figure 8: Operational Error Count and Metric Curves across Decision Thresholds (0.10 to 0.90)

5.2 Algorithmic Bias and Representativeness Limitations

Our proxy-group evaluation (analyzing performance stratified by domain age and IP-address presence) highlights that models trained on historical data can exhibit systematic bias against legitimate new businesses. For instance, newly incorporated startup domains inherently have an `age_of_domain = -1` (less than 6 months old), which strongly correlates with malicious kits in training data. Consequently, legitimate startups face higher baseline false-positive rates, risking anti-competitive suppression. Models must be retrained continuously with diverse, temporally balanced datasets to avoid static bias.

5.3 Privacy Concerns & Regulatory Compliance (GDPR / DPDP Act)

Real-world deployment of URL inspection systems requires intercepting user DNS queries, HTTP GET headers, and full browsing histories. Such deep telemetry logging creates substantial privacy hazards under privacy frameworks (such as the EU GDPR and India's Digital Personal Data Protection Act 2023). Organizations must enforce strict data minimization, client-side cryptographic hashing of query parameters, strict role-based access control (RBAC), and automated log retention purges.

5.4 Explainability & SOC Operational Feasibility

While the **MLP Neural Network** achieved the peak detection rate (96.56% accuracy), it functions as an opaque black box. In a live Security Operations Center (SOC), tier-1 analysts cannot afford to blindly accept model alerts; they require actionable explanations (e.g., 'flagged due to anchor URLs pointing to unverified IP address'). For this reason, a hybrid architecture is recommended: deploying **Logistic Regression** or **Decision Trees** at the edge for millisecond triage and human auditing, while routing ambiguous or high-confidence borderline alerts to the **MLP Neural Network** with a mandatory Human-in-the-Loop review path.

6. Conclusion & References

This project successfully developed, evaluated, and documented an end-to-end AI-driven threat detection prototype. Key conclusions include: (1) Machine learning achieves high accuracy (>92%) in distinguishing phishing attacks from benign web traffic; (2) Neural architectures improve detection performance (~96.5%) at the cost of opacity and compute; (3) Threshold calibration is essential to prevent catastrophic user lockouts; and (4) Ethical security governance requires human oversight and privacy protections.

Academic References:

1. Mohammad, R. & McCluskey, L. (2012). *Phishing Websites* [Dataset]. UCI Machine Learning Repository. <https://doi.org/10.24432/C51W2X>
2. Pedregosa, F. et al. (2011). Scikit-learn: Machine Learning in Python. *Journal of Machine Learning Research*, 12, 2825-2830.
3. NIST Special Publication 800-61 Rev. 2 (2012). *Computer Security Incident Handling Guide*. National Institute of Standards and Technology.
4. Goodfellow, I., Bengio, Y., & Courville, A. (2016). *Deep Learning*. MIT Press.